

CORSO DI CYBERSECURITY – EPICODE

REPORT DI LABORATORIO

Caccia al Malware con YARA

Report dell'Esercitazione

A cura di:

Nicola Madonna

Epicode

24 agosto 2026

Indice

1	Riassunto	2
2	Obiettivi	2
3	Configurazione del Laboratorio	3
3.1	Ambiente di laboratorio	3
3.2	Configurazione di rete	3
3.3	Installazione e configurazione	3
3.4	Verifica	3
4	Analisi dei Dati Raccolti	5
4.1	Struttura della directory analizzata	5
4.2	Individuazione del file malevolo	5
4.3	Conferma degli indicatori di compromissione	6
5	Conclusioni	7

1 Riassunto

Questo report descrive lo svolgimento di un'esercitazione incentrata sull'utilizzo di YARA, uno strumento per l'identificazione di file malevoli basato su pattern matching. L'esercizio si è articolato in due fasi: una prima fase introduttiva, in cui è stata creata una regola YARA di base per rilevare una stringa segreta all'interno di un file di testo di prova; una seconda fase operativa, in cui è stata scritta una regola più complessa per individuare, all'interno di una directory contenente migliaia di file di sistema Windows, un malware camuffato da processo legittimo. La caccia, condotta sulla piattaforma FLARE-VM, ha permesso di isolare con successo un unico file sospetto, `updater_service.exe`, confermato positivo su entrambi gli indicatori di compromissione forniti dal report di Threat Intelligence.

2 Obiettivi

- Comprendere la sintassi di base di una regola YARA (blocchi `strings` e `condition`).
- Creare e validare una regola YARA elementare su un file di prova (`config.txt`) contenente una stringa nota.
- Scrivere una regola YARA più avanzata, capace di rilevare un file malevolo tramite due indicatori distinti (una stringa testuale e una sequenza di byte esadecimali), combinati con l'operatore logico `or`.
- Eseguire una scansione ricorsiva (`-r`) su una directory di file di sistema per individuare un malware che ha alterato hash e nome file per eludere il rilevamento.
- Verificare ed estrarre gli offset esatti dei pattern rilevati tramite il flag `-s` (strings).

3 Configurazione del Laboratorio

3.1 Ambiente di laboratorio

L'esercizio è stato svolto interamente su FLARE-VM, una distribuzione Windows pre-configurata per l'analisi di malware e il reverse engineering, che include YARA (versione 4.5.5) già installato e disponibile da riga di comando come `yara64.exe`. Tutte le operazioni sono state eseguite tramite il Prompt dei comandi (CMD) di Windows, con i file di lavoro posizionati sul Desktop dell'utente `FlareVm`.

3.2 Configurazione di rete

L'esercizio non ha richiesto configurazioni di rete specifiche: tutte le operazioni sono state svolte in locale sulla macchina virtuale FLARE-VM, senza necessità di comunicazione con altri host o con l'esterno.

3.3 Installazione e configurazione

YARA era già presente nell'ambiente FLARE-VM, pertanto non è stata necessaria alcuna installazione aggiuntiva. La preparazione dell'ambiente di lavoro si è articolata in due fasi:

Fase 1 – Test di base. È stato creato un file `config.txt` sul Desktop contenente la stringa `Connessione_C2_Rilevata`, insieme a una prima regola YARA (`mia_regola.yar`) pensata per rilevarla:

```
rule Rileva_Finto_Malware {
    strings:
        $stringa_segreta = "Connessione_C2_Rilevata" ascii wide nocase
    condition:
        $stringa_segreta
}
```

Fase 2 – Caccia al malware. È stata scaricata la directory `Flare_Incident_Drive`, contenente una copia dei file di sistema Windows (cartelle `Program Data`, `Program Files`, `Program Files (x86)` e `Windows`) in cui era nascosto il file malevolo. È stata quindi scritta la regola `caccia_malware.yar`, basata su due indicatori di compromissione forniti da un report di Threat Intelligence relativo a uno specifico gruppo APT:

```
rule Caccia_Malware {
    strings:
        $stringa_apt = "AntiAV_Bypass_2026" ascii wide nocase
        $byte_injection = { E2 9A 12 FF }
    condition:
        $stringa_apt or $byte_injection
}
```

3.4 Verifica

Durante la creazione dei file `.yar` sono emersi alcuni errori di sintassi (`syntax error`, `unexpected identifier`), riconducibili a testo estraneo copiato insieme al codice della

regola. Prima di procedere con la scansione, sono state quindi verificate le proprietà del file `mia_regola.yar`, per confermare che l'estensione fosse effettivamente `.yar` e non `.yar.txt`.

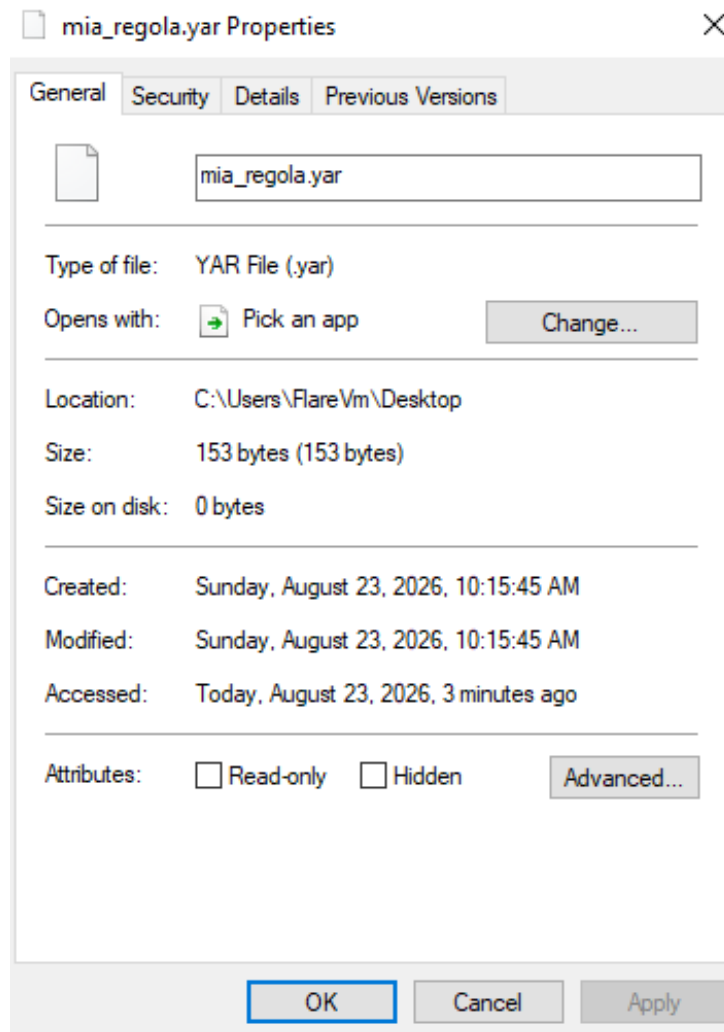


Figura 1: Proprietà del file `mia_regola.yar`: estensione e tipo file confermati corretti.

Una volta risolto il problema di sintassi, la regola di test è stata eseguita con successo contro `config.txt`, confermando il corretto funzionamento dell'ambiente YARA.

```
FLARE-VM Sun 08/23/2026 14:52:08.38
C:\Users\FlareVm\Desktop>
FLARE-VM Sun 08/23/2026 14:52:27.08
C:\Users\FlareVm\Desktop>yara64.exe mia_regola.yar config.txt
Rileva_Finto_Malware config.txt
```

Figura 2: Esecuzione riuscita della regola `Rileva_Finto_Malware` contro `config.txt`.

4 Analisi dei Dati Raccolti

Una volta validato il funzionamento di base di YARA, si è proceduto con la fase operativa dell'esercizio: la ricerca del file malevolo camuffato all'interno della directory di file di sistema.

4.1 Struttura della directory analizzata

La directory `Flare_Incident_Drive`, scaricata sul Desktop, riproduce la struttura di un file system Windows compromesso, con migliaia di file legittimi distribuiti su quattro sottocartelle principali (`Program Data`, `Program Files`, `Program Files (x86)`, `Windows`). La ricerca manuale del file malevolo in un volume di dati di queste dimensioni non sarebbe stata praticabile, il che giustifica l'approccio basato su pattern matching automatizzato.

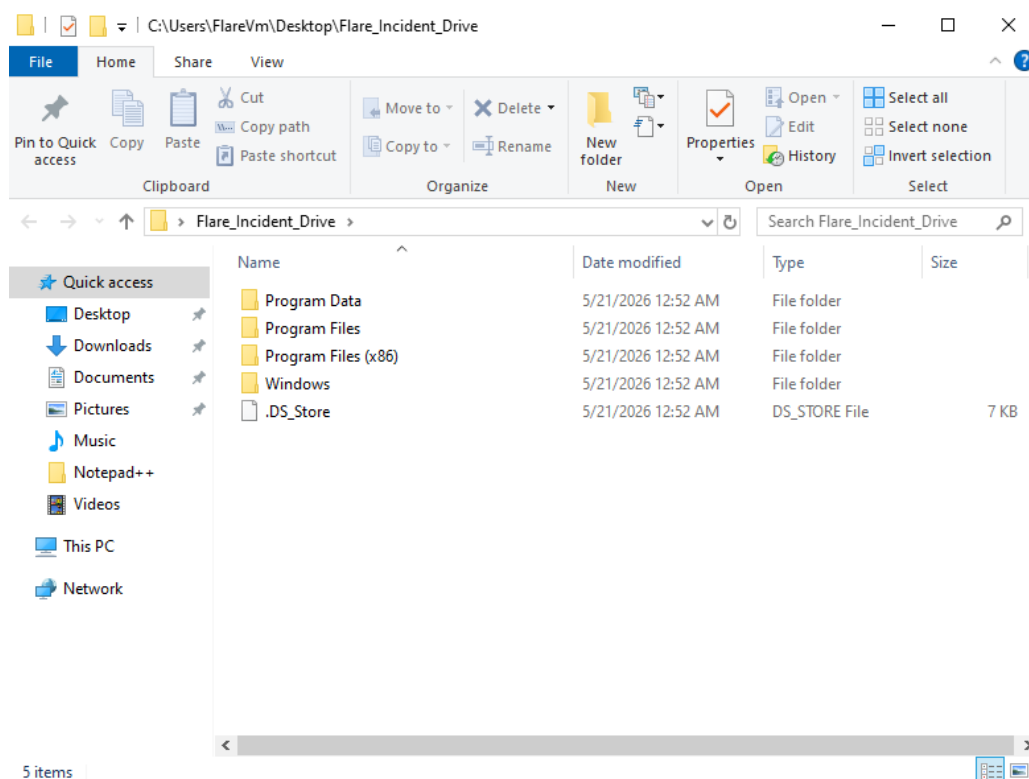


Figura 3: Struttura della directory `Flare_Incident_Drive` scaricata per l'analisi.

4.2 Individuazione del file malevolo

La scansione ricorsiva con la regola `Caccia_Malware` ha isolato un unico file positivo su tutto l'albero di directory:

```
yara64.exe -r caccia_malware.yar C:\Users\FlareVm\Desktop\Flare_Incident_Drive
```

```
FLARE-VM Sun 08/23/2026 15:15:27.41
C:\Users\FlareVm\Desktop>yara64.exe -r caccia_malware.yar C:\Users\FlareVm\Desktop\Flare_Incident_Drive
Caccia_Malware C:\Users\FlareVm\Desktop\Flare_Incident_Drive\Windows\System32\drivers\updater_service.exe
```

Figura 4: Output della scansione ricorsiva: rilevato il file `updater_service.exe`.

Il file individuato, `updater_service.exe`, era nascosto in `Windows\System32\drivers\`, una posizione plausibile per un driver di sistema legittimo, il che conferma la tecnica di camuffamento descritta nella traccia dell'esercizio.

4.3 Conferma degli indicatori di compromissione

Per verificare quale, tra i due indicatori definiti nella regola, avesse determinato il match, la scansione è stata ripetuta aggiungendo il flag `-s` (strings), che riporta offset e valore esatto di ogni pattern rilevato all'interno del file:

```
yara64.exe -s -r caccia_malware.yar C:\Users\FlareVm\Desktop\
Flare_Incident_Drive
```

```
FLARE-VM Sun 08/23/2026 15:15:58.93
C:\Users\FlareVm\Desktop>yara64.exe -s -r caccia_malware.yar C:\Users\FlareVm\Desktop\Flare_Incident_Drive
Caccia_Malware C:\Users\FlareVm\Desktop\Flare_Incident_Drive\Windows\System32\drivers\updater_service.exe
0x1336:$stringa_apr: AntiAV_Bypass_2026
0x1b51:$byte_injection: E2 9A 12 FF
```

Figura 5: Output con flag `-s`: entrambi gli indicatori rilevati nel file, con relativi offset.

Il file conteneva **entrambi** gli indicatori di compromissione previsti dalla regola, non solo uno dei due:

Tabella 1: Indicatori di compromissione rilevati nel file `updater_service.exe`.

Offset	Indicatore	Valore
0x1336	\$stringa_apr	AntiAV_Bypass_2026
0x1b51	\$byte_injection	E2 9A 12 FF

La presenza contemporanea di entrambe le firme rafforza in modo significativo l'attribuzione: non si tratta di un possibile falso positivo generato da un singolo pattern comune, ma di una corrispondenza doppia con le caratteristiche specifiche riportate nel bollettino di Threat Intelligence relativo al gruppo APT in questione.

5 Conclusioni

L'esercizio ha dimostrato in modo concreto il valore di YARA come strumento di threat hunting basato su indicatori di compromissione, in scenari in cui l'identificazione per hash o per nome file risulta inefficace a causa delle tecniche di offuscamento ed evasione adottate dagli attaccanti. Nella fase operativa, la combinazione di una stringa testuale e di una sequenza di byte esadecimali, unite tramite l'operatore **or**, ha permesso di individuare con precisione un singolo file malevolo su un volume di migliaia di file di sistema legittimi, senza alcun falso positivo.

Il dato più interessante emerso dall'analisi è la presenza simultanea di entrambi gli indicatori all'interno dello stesso file: se da un lato ciò conferma con maggiore certezza l'attribuzione al gruppo APT descritto nel report di Threat Intelligence, dall'altro suggerisce che in un contesto reale una regola scritta con un operatore **and** al posto di **or** avrebbe comunque prodotto lo stesso risultato, offrendo un livello di confidenza ancora più elevato e riducendo il rischio di falsi positivi generati da uno solo dei due pattern.

Come sviluppo futuro, l'esercizio potrebbe essere esteso integrando regole YARA basate su repository di Threat Intelligence pubblici (ad esempio YARA-Rules o Neo23x0/signature-base), automatizzando la scansione periodica di directory di sistema e valutando l'impatto delle performance di YARA su volumi di dati significativamente più grandi rispetto a quello utilizzato in laboratorio.